

FinTrack Production Readiness Assessment

Document owner: Engineering

Version: 1.0

Status: Draft for review

Scope: What must be done, in what order, and what it will cost for FinTrack to be safely usable by real-world end users.

1. Executive summary

FinTrack is a feature-complete personal finance application. The product surface is broad: linked bank accounts, transaction sync, budgets, goals, bills, debt planning, AI analysis, an AI assistant, savings vault, tax organizer, household accounts, web push notifications, and a native mobile wrapper for Android and iOS.

The application is **not yet ready for public end users** in its current state. The functional gaps are smaller than the operational, security, and compliance gaps. Everything in this document is achievable, but it requires a structured programme of work, not a single release.

This assessment classifies work into four priority tiers:

Tier	Definition	Indicative cost
P0	Must exist before any real users	USD 21,000 - 38,000
P1	Required for a controlled public launch	USD 13,000 - 25,000
P2	Required within 12 months of launch	USD 9,000 - 18,000
P3	Recommended growth and resilience work	USD 6,000 - 14,000

Estimated total one-time build: USD 49,000 - 95,000

Estimated ongoing monthly operating cost: USD 850 - 3,100 (details in section 10)

Readiness score today: **~4 out of 10** for general consumers; ~6 out of 10 for a small closed beta.

2. Readiness scorecard

Each domain is scored 0 - 5 against what a public fintech product must meet.

Domain	Score	Summary
Product and UX completeness	4 / 5	Broad feature set; gaps in empty states, error recovery, and help

Core security	4 / 5	Strong foundations (bcrypt, AES-GCM, JWT) plus rate limiting, CSP/HSTS headers. Missing audit log, secret rotation, DDoS protection
Compliance and legal	1 / 5	No privacy policy, terms, data processing agreements, or financial disclosures
Infrastructure and reliability	2 / 5	Single region, no backups, no monitoring, no alerting, no SLOs
Data and privacy	2 / 5	Retention policy absent, no data export or deletion automation, weak consent flows
Bank connectivity	3 / 5	Plaid integrated and encrypted. Webhook sync, reconciliation, and disaster recovery missing
AI reliability	3 / 5	Local fallback engine exists. No PII redaction, no usage budgets, no hallucination guardrails
Mobile store readiness	2 / 5	APK builds. No signed release builds, no app store assets, no privacy nutrition labels
Monitoring and support	1 / 5	No error tracking, no logs, no support channel, no user feedback loop
Accessibility	2 / 5	Basic aria labels. No WCAG audit, no contrast/FA audits
Performance	3 / 5	Fast in common paths. No CDN, no load testing, no pagination on large datasets
Testing	2 / 5	No automated test suite, no CI test stage, no load tests, no staging environment

3. P0: Required before any real users

3.1 Security hardening

Current state: bcrypt (cost 12), AES-256-GCM token encryption, JWT with HttpOnly cookies, NextAuth CSRF, email verification, Zod input validation.

Gaps and required work

- ~~Rate limiting on every authentication and AI endpoint.~~ **Done.** An in-memory limiter (`lib/rate-limit.ts`) now throttles register, forgot-password, verify-email, reset-password, change-email, change-password, chat, and intelligence endpoints.
 - Remaining: scale to an external store (Upstash Ratelimit or Vercel edge rate limiting middleware) for multi-region deployments.
 - Effort: 2 - 4 days (partially done).
- ~~Security headers and DDoS protection.~~ **Headers done.** CSP, HSTS, X-Content-Type-Options, X-Frame-Options, Referrer-Policy, and Permissions-Policy set in `next.config.js` .

- Remaining: enable Vercel WAF or Cloudflare in front.
 - Effort: 1 - 3 days (partially done).
3. **Secrets management and rotation.** `ENCRYPTION_KEY` , `NEXTAUTH_SECRET` , Plaid secrets, SMTP credentials, and the Anthropic key must be in a vault (Vercel Env / Doppler / AWS Secrets Manager), with a documented rotation runbook. Add a KMS-backed key versioning plan so a rotated encryption key can re-encrypt stored Plaid tokens.
- Effort: 3 - 5 days.
4. **Audit log.** Record security-relevant events: login, failed login, password change, email change, account link, account unlink, data export, settings change.
- New `AuditLog` table + middleware in write paths.
 - Effort: 4 - 6 days.
5. **Session hardening.** Shorten JWT expiry, add sliding sessions, and revoke sessions on password change. Consider server-side session store.
- Effort: 2 - 4 days.
6. **Penetration test.** Engage a third party after hardening is complete (USD 3,000 - 15,000 depending on scope).

3.2 Compliance and legal (non-negotiable before launch)

Engage legal counsel for all of the following. Template costs assume a startup-friendly fintech law firm.

1. **Terms of Service** (USD 1,500 - 4,000).
2. **Privacy Policy** that documents data collected, processors, purpose, retention, and user rights under GDPR/CCPA (USD 1,500 - 4,000).
3. **Cookie and consent banner** with legitimate-interest settings (USD 500 - 1,500 implementation + template licence).
4. **Data Processing Agreement** with cloud and AI providers (USD 500 - 1,500).
5. **Data retention schedule and deletion policy**, with automated enforcement (GDPR Article 5(1) (e)) (USD 2,000 - 4,000 engineering).
6. **Financial services disclosures.** The app analyses finances but does not move money or give regulated advice. Still required: disclaimers that FinTrack is not a bank, not a financial adviser, and that AI output is informational. Confirm with counsel whether a money-services or e-money licence is triggered in each launch market. For most markets, an informational analysis tool does not require a licence, but legal confirmation is mandatory before launch (USD 1,000 - 5,000 opinion).
7. **AI output compliance.** Provide a model card / disclosure that AI analysis is generated and may be wrong; add "not financial advice" wording to all AI surfaces (small).

3.3 Infrastructure, backups, and monitoring

1. **Production database on a managed Postgres** (Neon/Supabase/RDS) with:
 - Point-in-time recovery enabled.
 - Automated daily backups with retention and restore drill (monthly).
 - Read replica if growth requires it.
 - Cost: from USD 19 - 120 / month on Neon/RDS.
2. **Uptime and error monitoring.**
 - Sentry (error tracking, front and back end) - Free tier to USD 26 / month.
 - Vercel analytics + uptime checks, or Betterstack/UptimeRobot - Free to USD 40 / month.
 - Structured logs: Vercel Logs or Axiom - Free to USD 25 / month.
3. **SLOs and runbooks.** Define 99.5% availability target, alert thresholds for sync failures, Plaid outage handling, AI outage fallback.
 - Effort: 3 - 5 days.
4. **Staging environment.** A second Vercel project + database that mirrors production for testing migrations and deploys.
 - Cost: database from USD 19 / month; minimal additional hosting.
5. **Deployment guardrails.** Enforce CI checks (typecheck, lint, tests) before merge; add a database migration review step for `prisma migrate`.

3.4 Data and privacy engineering

1. **Data export (GDPR Article 20).** Export all user data as JSON/CSV (effort: 3 - 5 days).
2. **Account deletion.** Hard-delete flow with cascading cleanup of Plaid items (via `item/remove`), push subscriptions, receipts, and cached AI insights (effort: 3 - 5 days).
3. **Right-to-erasure automation** for unverified accounts after a retention window.
4. **PII handling review.** Ensure AI prompts receive only necessary transaction fields; add prompt-level redaction and an option to disable AI processing (effort: 2 - 4 days).

3.5 P0 cost summary

Item	Effort	Cost
Rate limiting	2 - 4 days	USD 800 - 1,600
Security headers + WAF	1 - 3 days	USD 400 - 1,200
Secrets management + rotation runbook	3 - 5 days	USD 1,200 - 2,000
Audit log	4 - 6 days	USD 1,600 - 2,400

Session hardening	2 - 4 days	USD 800 - 1,600
Penetration test	external	USD 3,000 - 15,000
Legal: ToS + Privacy + DPA + disclosures	external	USD 3,500 - 12,000
Cookie consent	2 - 3 days	USD 800 - 1,200
Data retention + deletion + export + erasure	8 - 12 days	USD 3,200 - 4,800
AI prompt redaction + disclosures	2 - 4 days	USD 800 - 1,600
Managed DB + backups + monitoring + logging	4 - 6 days + infra	USD 1,600 - 2,400 + ~USD 100 - 180/month
Staging environment + CI guardrails	3 - 5 days	USD 1,200 - 2,000

P0 subtotal: approximately USD 19,000 - 47,000 (engineering USD 14,000 - 25,000 plus external legal and security USD 6,500 - 27,000).

4. P1: Required for a controlled public launch

4.1 Testing

There is currently no automated test suite. Before public launch you need:

1. **Unit tests** for the AI analysis engine, currency utilities, categorization rules, and encryption/decryption. Vitest + Testing Library (5 - 8 days).
2. **API integration tests** for auth, transactions, budgets, goals, Plaid exchange/sync (mocked Plaid), and chat (7 - 12 days).
3. **E2E smoke tests** for the critical journeys: register, verify email, link a bank, view dashboard, add a manual transaction, chat (Playwright) (5 - 8 days).
4. **CI pipeline** running typecheck, lint, unit, and integration tests on every PR (2 - 3 days).
5. **Load test** of the dashboard and intelligence endpoints with k6 to confirm the serverless configuration holds (2 - 3 days).

Cost: USD 8,000 - 16,000.

4.2 Bank connectivity reliability

1. **Plaid webhooks.** Register `SYNC_UPDATES_AVAILABLE` webhooks so transactions update when the bank pushes changes, not only on manual sync. Add webhook signature verification. This is a P1 because users will otherwise see stale balances daily (4 - 6 days).
2. **Automated daily sync** for all users via a scheduled job (Vercel Cron) with per-item backoff on Plaid rate limits (3 - 5 days).

3. **Sync status and error surface.** Show "Last synced" errors and a retry affordance; surface Plaid error codes (ITEM_LOGIN_REQUIRED etc.) with actionable messages (3 - 5 days).
4. **Reconciliation check.** A nightly job that cross-checks fetched totals so silent sync failures are caught (2 - 4 days).
5. **Legacy cleanup.** ~~Rename the Teller era schema fields (`tellerToken` / `tellerAccountId` / `tellerId`) to Plaid names and remove Teller references from the landing page.~~ **Done.** Fields renamed to `accessToken` / `plaidAccountId` / `plaidTransactionId` and the landing page now references Plaid. A final sweep for leftover Teller calls is advised (0 - 1 days).

Cost: USD 6,000 - 11,000.

4.3 Mobile store readiness

1. **Release signing.** Configure Android release keystore and iOS signing; replace the debug-only CI build (1 - 2 days).
2. **App icons, splash screens, and store screenshots** for Play Console and App Store (design USD 500 - 3,000).
3. **Store listings** (title, description, category, screenshots, release notes) (1 - 2 days).
4. **Data-safety / privacy nutrition labels** matching the privacy policy (1 - 2 days).
5. **Play Console closed testing track** (beta testers) then production; App Store TestFlight.
6. **Deep linking.** Configure Capacitor deep links for verify/reset email links so the native app opens them (2 - 3 days).

Cost: USD 1,500 - 6,000 (including design) plus the Apple Developer Program USD 99/year and Google Play USD 25 one-time.

4.4 AI reliability and cost control

1. **Token/cost budgets.** Cap analysis runs per user per day; estimate token consumption; add a kill switch and caching improvements. The 1-hour insight cache already exists; extend it (3 - 4 days).
2. **PII and prompt hygiene.** Confirm transaction data is minimized before it reaches Claude; log usage without logging raw data (2 - 3 days).
3. **Hallucination guardrails.** Add a "verify with source data" footer to AI claims; every claim links to the underlying transactions or a cached number (3 - 4 days).
4. **Fallback telemetry.** Track how often the local fallback engine is used so the team knows when Claude is down (1 - 2 days).

Cost: USD 4,000 - 7,000.

4.5 Support and feedback

1. **In-app support.** Help centre, contact form, or Intercom-style widget (USD 0 - 89/month; effort 2 - 3 days).
2. **Feedback loop.** Structured in-app feedback with opt-in diagnostics (2 - 3 days).
3. **Shared support inbox** and a weekend SLAs policy. For a small team, a support tool like Crisp/Intercom from USD 0 - 25/month.
4. **Status page** (Vercel status or free tier of a provider) (half day).

Cost: USD 1,500 - 4,000 plus USD 0 - 114/month tooling.

4.6 P1 cost summary

Item	Cost
Automated testing + CI + load test	USD 8,000 - 16,000
Bank connectivity reliability	USD 6,000 - 11,000
Mobile store readiness	USD 1,500 - 6,000
AI reliability and cost control	USD 4,000 - 7,000
Support and feedback	USD 1,500 - 4,000

P1 subtotal: approximately USD 21,000 - 44,000.

5. P2: Required within 12 months of launch

1. **Multi-currency and exchange-rate features** are partially built. Complete account-level FX handling and clearly label display conversions vs. real converted balances (4 - 6 days).
2. **Budget notifications and alert delivery.** Make bill reminders, overspend alerts, and goal progress deterministic (scheduled jobs + push/web) (5 - 8 days).
3. **Household accounts.** The schema exists; complete invitation flows, permissions, and shared budget visibility (6 - 10 days).
4. **Credit score and investments data** need a live provider (or clearly labelled manual entry) or they read as unfinished surfaces (5 - 8 days).
5. **Receipt storage.** Receipts are stored as raw blobs in the database; move to object storage (S3-compatible) and keep the DB for metadata (3 - 5 days).
6. **Performance work.** Paginate transactions, virtualize long lists, and add an index check for large users (3 - 5 days).
7. **Accessibility pass.** WCAG 2.1 AA: colour contrast, focus states, screen-reader labels, and reduced-motion verification (4 - 6 days).

8. **Localisation foundation.** Internationalize strings and date/currency formats; launch in English only but architect for i18n (4 - 6 days).

P2 estimated cost: USD 15,000 - 30,000.

6. P3: Recommended growth and resilience

1. **Referral and invite programme** (5 - 8 days).
2. **Monthly email digest** of spending (5 - 8 days).
3. **A/B testing framework** for onboarding and dashboard (3 - 5 days).
4. **Advanced fraud detection signals** on unusual logins (IP/device) (4 - 6 days).
5. **Disaster recovery plan and multi-region option** (2 - 4 days + infrastructure).
6. **Annual security review** (ongoing USD 2,000 - 8,000/year).

P3 estimated cost: USD 8,000 - 18,000.

7. What is already done well

- Password hashing with bcrypt cost factor 12.
 - AES-256-GCM encryption of bank tokens at rest with an explicit key-length guard.
 - Email verification gate on all dashboard routes via middleware.
 - Zod validation on API inputs.
 - A deterministic local AI fallback so the assistant works without the Claude API.
 - Cached AI insights (1-hour TTL) reducing cost and latency.
 - Pull-to-refresh, haptics, and mobile-first layouts in the native wrapper.
 - CI workflow that builds APK/IPA artifacts.
-

8. What is NOT present and needs building first (short list)

The following are the highest-leverage items. Everything else in this document can follow.

1. Legal (ToS, Privacy Policy, DPA, disclosures).
2. Rate limiting on auth and AI endpoints.
3. Managed database backups + point-in-time recovery.
4. Error monitoring (Sentry) and structured logging.
5. Plaid webhooks + automated daily sync.

- 6. Data export and account deletion.
- 7. Automated test suite and CI test stage.
- 8. Release-signed mobile builds.
- 9. Security headers and a WAF/DDoS layer.
- 10. Audit log.

9. Suggested 16-week launch roadmap

Weeks	Focus	Deliverable
1 - 2	Legal + security foundations	ToS, Privacy Policy, DPA, disclosures; external rate-limiting store; WAF/DDoS layer; secrets vault
3 - 4	Data and privacy engineering	Export, deletion, retention, erasure automation, AI prompt hygiene
5 - 6	Infrastructure	Managed DB with PITR, Sentry, logging, alerting, staging, CI guardrails
7 - 8	Bank reliability	Plaid webhooks, scheduled sync, error surfacing, reconciliation, schema cleanup
9 - 10	Testing	Unit, integration, E2E, load; CI test stage
11 - 12	AI hardening + cost control	Budgets, guardrails, fallback telemetry
13 - 14	Mobile store readiness	Signing, icons, store listings, TestFlight + Play closed track
15	Support + feedback	Help centre, status page, feedback loop
16	Pen test + go/no-go review	External pen test, fix criticals, launch controlled beta

10. Operating cost estimate (monthly, post-launch)

Item	Cost per month
Hosting: Vercel Pro	USD 20
Database: managed Postgres (Neon/RDS)	USD 19 - 120
Monitoring: Sentry + uptime + logs	USD 0 - 91
Plaid production	USD 0 - 1,500 (usage-based; see note)
Anthropic Claude	USD 0 - 500 (usage-based; see note)
Email (SMTP)	USD 0 - 20

Push notifications	USD 0
Support tool (Intercom/Crisp)	USD 0 - 114
Apple Developer Program	USD 8 (annual USD 99)
Object storage (receipts)	USD 0 - 10
Total	USD 50 - 2,400 + variable Plaid/AI

Notes on variable costs

- Plaid charges per end user per month when the item connects to production data. Pricing is account- and market-dependent and typically in the range of USD 0.50 - 2.00 per user per month. At 500 users this is roughly USD 250 - 1,000/month. Confirm current pricing on Plaid's website.
- Claude costs depend on transaction volume and analysis frequency. With a 1-hour cache, a budget cap of a few analysis runs per user per day, and the local fallback, expect roughly USD 0.10 - 1.00 per active user per month at current token pricing. At 500 active users this is USD 50 - 500/month.
- **Worst-case realistic month (500 users): USD 350 - 2,400 plus your Plaid commitment.**

11. Costing assumptions

- Engineering rate of USD 400/day (full-time senior or agency equivalent) unless noted otherwise.
- Legal is billed per engagement; figures are typical ranges for a startup fintech firm, not quotes.
- Plaid and Anthropic pricing are usage-based and change over time; figures are planning estimates, confirm before budgeting.
- Effort figures assume one engineer; the calendar duration of the 16-week roadmap assumes 2 engineers working in parallel on independent tracks (e.g. legal/security vs. infrastructure vs. bank connectivity).

12. Decision checklist

Before the first real user signs up, all of the following must be **yes**:

- ☐ ToS, Privacy Policy, and AI disclosures published and linked from signup.
- ☐ Rate limiting active on auth and AI endpoints.
- ☐ Database has point-in-time recovery and verified restore drills.
- ☐ Sentry and uptime alerts are firing on staging.

- ☐ Data export and account deletion work end to end.
- ☐ Plaid webhooks and scheduled daily sync are live in production.
- ☐ CI blocks merges on failed tests.
- ☐ Mobile builds are release-signed and store-ready.
- ☐ Penetration test completed and critical findings resolved.
- ☐ A human receives support emails and a status page exists.